NAVY POČÍTAČOVÁ BEZPEČNOST

Cv4. Neoprávněný přístup a odhalení citlivých dat (Broken access & Directory Listing)

Cíl cvičení: Pochopit, jak útočníci získávají přístup k datům, která jim nepatří. Zkusíte si dvě různé techniky: manipulaci s daty v paměti prohlížeče (zranitelnost IDOR) pro zobrazení cizího nákupního košíku a zneužití špatně nastaveného serveru (Directory Listing) k nalezení tajných firemních dokumentů.

Teoretický úvod: Zabezpečení nesmí spoléhat na náhodu

Mnoho webových aplikací trpí tím, že vývojáři příliš důvěřují uživatelům nebo spoléhají na to, že „co není vidět, to nikdo nenajde“ (tzv. *Security through obscurity*). Dnes si ukážeme dvě typická selhání:

1. **IDOR (Insecure Direct Object Reference):** Ve světě webů server často slepě důvěřuje číslu (ID), které mu váš prohlížeč pošle. Pokud ID změníte na jiné a server neověří, zda k němu máte práva, můžete číst cizí data (např. cizí objednávky). Tomu se říká *Broken Access Control*.
2. **Directory Listing (Výpis adresáře):** Administrátoři někdy nechají na serveru tajné dokumenty s tím, že na ně nevede žádný odkaz, takže je přece nikdo nenajde. Pokud je ale server špatně nastaven, stačí zadat do prohlížeče cestu ke složce a server vám poslušně vypíše seznam všech souborů uvnitř.

Část 1: Pohled do cizího košíku (Útok pomocí IDOR)

Abyste mohli ukrást cizí košík, musíte nejprve pochopit, jak si aplikace pamatuje ten váš. Neukládá ho totiž do URL adresy, ale do vnitřního úložiště prohlížeče.

Krok 1: Příprava

- Ujistěte se, že jste přihlášeni (např. jako administrátor).
- Na hlavní stránce přidejte libovolný produkt (např. Apple Juice) do košíku.
- Zkontrolujte, že v něm produkt opravdu je.

Krok 2: Kde je můj košík?

- Stiskněte **F12** pro otevření Vývojářských nástrojů.
- Přejděte do záložky **Application** (nebo *Storage / Úložiště*).
- V levém menu rozbalte **Session Storage** (Úložiště relace) a klikněte na adresu e-shopu. Zde vidíte data, která si o vás prohlížeč pamatuje.

Krok 3: Samotný útok

- Najděte v tabulce klíč, který reprezentuje ID vašeho košíku a hodnotu přepište.
- Stiskněte **F5** (obnovení stránky). Pokud vidíte cizí produkty, úspěšně jste zneužili IDOR! Na Scoreboardu se vám odškrtne úkol *"View Basket"*.

Část 2: Hledání tajného pokladu (Útok pomocí Directory Listing)

Nyní víte, že aplikace má mezery v ověřování práv. Zkusíme zjistit, jestli nemá i špatně nastavený server, který nám prozradí víc, než by měl.

Krok 4: Hledání stop

- Jděte do hlavního menu e-shopu a najděte stránku **About Us** (O nás).
- Najděte odkaz na dokument **Terms of Use** (Podmínky použití) a klikněte na něj.
- Podívejte se pozorně do adresního řádku prohlížeče (URL) a zjistěte, v jaké složce se soubor nachází (např. složka /ftp/).

Krok 5: Zvědavost se vyplácí

- V adresním řádku smažte jméno konkrétního souboru (např. legal.md), ale **ponechte název složky a lomítko** (např. http://localhost:3000/ftp/).

Krok 6: Nalezení pokladu

- Prohlédněte si seznam souborů. Zajímají nás zálohy (končící na .bak) nebo interní firemní plány.
- **Akce:** Najděte a otevřete dokument, který může obsahovat z pohledu firmy citlivé a zneužitelné údaje.
- Jakmile dokument přečtete, na Scoreboardu získáte splnění úkolu *"Confidential Document"*. *(Bonus: Najděte ve stejné složce i zálohu konfiguračního souboru)*

Nástroje z praxe:

Profíci většinou neupravují data ručně přes *Session Storage* nebo adresní řádek. K manipulaci s daty za běhu používají proxy nástroje (např. **Burp Suite** nebo **OWASP ZAP**). K hledání skrytých složek pak nasazují automatizované nástroje jako **DirBuster**, **Gobuster** nebo **ffuf**, které zkouší tisíce názvů za vteřinu.

Bonusový úkol: Překonání filtru a stažení zakázané zálohy (File Extension Bypass)

Cíl cvičení: Zjistit, že nalezení citlivého souboru je jen polovina úspěchu. Tou druhou je překonání špatně napsaného filtru, který má chránit stahování nepovolených typů souborů.

Teoretický úvod:

Vývojáři e-shopu si uvědomili, že ve složce /ftp/ mohou být citlivá data. Nastavili proto pravidlo: *„Dovol uživateli stáhnout soubor, pouze pokud jeho název končí na .md nebo .pdf“*.

Co se ale stane, když serveru pošlete požadavek na stažení souboru ve formátu tajnazaloha.bak[NĚCO].md? Server uvidí na konci .md a požadavek povolí. Jak ale donutit operační systém, aby to [NĚCO] a všechno za tím ignoroval a sáhl po správném souboru? K tomu slouží historický trik zvaný **Null Byte** (nulový bajt), který systému říká: *"Tady textový řetězec končí, dál už nečti."*

Krok 1: Náraz do zdi

- Vraťte se do složky /ftp/ z předchozího úkolu.
- V seznamu souborů vidíte zálohu konfiguračního souboru vývojářů: package.json.bak.
- Zkuste na ni kliknout nebo ji stáhnout. Aplikace vám vyhodí chybu (např. *403 Forbidden*), protože stahovat se smí jen .md a .pdf.

Krok 2: Oklamání filtru (Útok) Vaším úkolem je upravit URL adresu tak, aby si bezpečnostní filtr myslel, že stahujete .md soubor, ale server vám přitom reálně poslal .bak soubor.

Postupné nápovědy (použijte je, až když se zaseknete):

- 💡 **Nápověda:** Do názvu souboru musíme vložit speciální znak (Null Byte) mezi .bak a .md. V URL adrese se Null Byte zapisuje jako %00. V některých moderních aplikacích je ale nutné ho tzv. "dvojitě zakódovat" (Double URL encoding), což vypadá takto: %2500.

Úspěšné dokončení

Na scoreboardu se postupně odškrtnou úkoly:

- *View Basket.*
- *Confidential Document.*
- *Forgotten Developer Backup.*